

# AgentSight

## Remediation & Production-Grade Implementation Specification

Document à fournir à GitHub Copilot pour corriger, compléter et tester le projet

Projet analysé : xsaidi1992/preemptics-test | Branche cible : main | 15 août 2026

### OBJECTIF NON NÉGOCIABLE

Transformer le prototype actuel en prototype eBPF réellement end-to-end : événement kernel réel -> ring buffer réel -> consumer userspace réel -> modèle Python -> corrélation de session -> security engine -> API, avec des tests qui prouvent chaque maillon sans injecter artificiellement les événements attendus.

# 1. Résumé exécutif

Le projet présente une architecture de supervision de sécurité pour agents IA intéressante et déjà bien structurée : instrumentation kernel, transport d'événements, modèles Python, corrélation processus/session, moteur de règles et API. Le principal défaut restant est que le chemin eBPF n'est pas encore prouvé de bout en bout : le programme peut être compilé/chargé/attaché, mais la consommation live du BPF ring buffer vers Python reste le maillon critique.

## Verdict

Le livrable final ne doit plus pouvoir être qualifié de "simulation eBPF". Un test Linux privilégié doit pouvoir lancer `/bin/echo`, observer un événement provenant du kernel, vérifier son PID/filename, le faire apparaître dans la session et le retrouver via l'API. Toute solution qui construit directement `ProcessExecutionEvent` dans le test ne valide pas l'eBPF live.

| Domaine             | État actuel                                         | Cible                                                    |
|---------------------|-----------------------------------------------------|----------------------------------------------------------|
| Loader eBPF         | Chemin compile/load/attach présent                  | Chargement/attachement robuste + états explicites        |
| Ring buffer         | Écriture kernel présente, consumer Python incomplet | Consumer live réel et continu                            |
| Détection de pertes | Séquence insuffisante pour tous les drops           | sequence + drop counter vérifiables                      |
| Portabilité         | Dépendances au layout tracepoint / tooling local    | CO-RE/BTF/libbpf recommandé                              |
| Fichiers/réseau     | Partiellement simulés ou observés indirectement     | Probes kernel dédiés ou périmètre explicitement réduit   |
| Security engine     | Règles statiques simples                            | Corrélation contextuelle multi-événements                |
| API                 | Bonne démo, mémoire locale                          | Auth, limites, stockage/indexation ou limites explicites |
| Tests               | Unitaires/intégration simulée utiles                | Vrais tests e2e kernel + stress + pertes + sécurité + CI |

# 2. Architecture cible obligatoire

La chaîne suivante doit exister réellement, avec des interfaces testables et des métriques de santé :

```
Linux kernel
-> eBPF programs (exec, exit; puis fichiers/réseau selon scope)
-> BPF_MAP_TYPE_RINGBUF
-> userspace ring-buffer consumer
-> binary event decoder / schema validation
-> ProcessExecutionEvent / FileAccessEvent / NetworkConnectionEvent
-> SessionManager / process-tree correlation
-> SecurityEngine / correlation rules
-> persistence or bounded in-memory store
-> FastAPI
-> observability: health, drops, last event, probe state
```

- Aucune étape critique ne doit être simulée dans les tests e2e.

- Les tests unitaires peuvent utiliser des événements synthétiques, mais ils doivent être clairement séparés des tests kernel live.
- Le collector doit exposer son état exact : unsupported, preflight\_ok, compiled, loaded, attached, streaming, degraded, error.

### 3. Corrections techniques prioritaires

#### P0-1 - Implémenter le consumer live du ring buffer

Le probe réserve et soumet des événements dans un BPF ring buffer, mais le chemin Python actuel accepte encore des payloads déjà décodés. Implémenter un consumer réel utilisant libbpf, un binding approprié, ou un petit bridge natif stable. Le consumer doit ouvrir la map events, poller, décoder la structure binaire, valider les tailles/version de schéma et appeler le pipeline Python.

#### P0-2 - Prouver l'attachement réel du programme

Ne pas considérer un simple preflight comme une injection réussie. Remplacer les booléens ambigus par des états explicites. Le statut ATTACHED doit provenir d'une opération d'attachement réussie; STREAMING seulement après réception d'au moins un événement ou après initialisation effective du polling.

#### P0-3 - Corriger les pertes du ring buffer

BPF\_MAP\_TYPE\_RINGBUF ne "droppe" pas automatiquement le plus ancien événement comme une sliding window. Si bpf\_ringbuf\_reserve échoue, le nouvel événement n'est pas produit. Corriger commentaires/README et ajouter un compteur de drops. Incrémenter la séquence avant la tentative de reserve ou maintenir sequence\_total + drops\_total séparés.

#### P0-4 - Rendre le test e2e réellement kernel-driven

Créer un test privilégié qui lance le collector, exécute un processus réel, puis attend l'événement kernel correspondant. Interdiction d'instancier ProcessExecutionEvent pour simuler l'événement attendu dans ce test.

#### P1-1 - Fiabiliser le chargement avec CO-RE/libbpf

Privilégier BPF CO-RE, BTF et libbpf skeleton. Éviter une dépendance fragile à une commande bpftool attach si elle ne correspond pas exactement au type d'attachement. Le programme doit être compatible avec plusieurs kernels supportés par la matrice de tests.

#### P1-2 - Stabiliser le schéma binaire

Définir un event header/version, tailles fixes, alignement documenté et tests ABI. Vérifier sizeof(struct event) côté C et côté consumer. Refuser proprement une version inconnue.

#### P1-3 - Process lifecycle complet

Ajouter sched\_process\_exit au minimum pour fermer correctement l'état des processus et éviter l'accumulation de PID morts. Tester PID reuse et parent/child correlation.

#### P1-4 - Scope fichiers et réseau clair

Soit implémenter de vrais probes pour open/openat/openat2, unlink/unlinkat, rename, connect/sendto selon le besoin; soit annoncer explicitement que ces catégories ne sont pas encore kernel-live. Ne pas présenter /proc/<pid>/fd comme un flux d'événements équivalent à openat.

## P1-5 - Security engine contextuel

Faire évoluer les règles simples vers des corrélations : fichier sensible lu puis connexion externe, exécution inattendue pour un profil d'agent, écriture/suppression après élévation, destination allowlist/denylist, fréquence/anomalie. Les alertes doivent avoir un rule\_id stable et des preuves.

## P1-6 - API et sécurité

Ajouter authentification configurable pour le mode exposé, contrôle d'accès, validation stricte, limites de pagination, limites de requêtes et endpoints health/readiness. Ne pas exposer par défaut des données sensibles sur 0.0.0.0 sans protection.

## P2-1 - Stockage et scalabilité

Éviter le scan O(N) de toutes les sessions pour chaque recherche en production. Introduire un repository abstrait; SQLite convient au prototype durable, puis PostgreSQL/ClickHouse/OpenSearch selon le volume. Garder un backend in-memory pour les tests.

## P2-2 - Nettoyage du repository

Supprimer \_\_pycache\_\_, ranger scripts/PDFs, normaliser tests/, ajouter pyproject.toml, lint/type-check, documentation de build et commandes reproductibles.

# 4. Machine d'état du runtime eBPF

| État         | Signification                           | Condition de sortie                 |
|--------------|-----------------------------------------|-------------------------------------|
| UNSUPPORTED  | Kernel/tooling/capability non supportés | Erreur explicite; fallback éventuel |
| PREFLIGHT_OK | Prérequis présents                      | Compilation autorisée               |
| COMPILED     | Objet BPF produit et vérifié            | Load                                |
| LOADED       | Programme/maps chargés dans le kernel   | Attach                              |
| ATTACHED     | Hook attaché au bon tracepoint          | Start consumer                      |
| STREAMING    | Polling actif; événements consommables  | Stop/error/degraded                 |
| DEGRADED     | Drops, decode errors ou probe partiel   | Recovery ou stop                    |
| ERROR        | Échec explicite avec cause structurée   | Retry/stop                          |

Le endpoint /health doit exposer au minimum : runtime\_state, attached\_programs, consumer\_running, events\_received\_total, events\_decoded\_total, decode\_errors\_total, kernel\_drops\_total, sequence\_gaps\_total, last\_event\_timestamp, queue\_depth et version du schéma.

# 5. Exigences du ring buffer consumer

- Décodage strict et borné : aucune lecture hors taille, aucun cast non vérifié.
- Le callback doit rester rapide : décoder puis pousser dans une queue bornée; traitement lourd hors callback.
- Backpressure explicite côté userspace : compteur de queue drops distinct des kernel ring-buffer drops.
- Arrêt propre : le thread/tâche de polling doit pouvoir être stoppé sans fuite FD/map/link.
- Reconnexion/reload : après erreur du consumer, le runtime doit passer en DEGRADED/ERROR; aucune fausse apparence de santé.

- Chaque événement doit porter timestamp monotonic kernel, pid/tgid pertinents, uid/gid, comm, filename et sequence/version selon schéma.
- Les métriques de perte doivent être monotones et testables.

## 6. Exigences eBPF et compatibilité kernel

- Utiliser sched\_process\_exec pour les exec réussis; ajouter sched\_process\_exit pour le lifecycle.
- Valider la sémantique PID/TGID et PPID. Si le layout du tracepoint ne fournit pas le parent, utiliser bpf\_get\_current\_task\_btf + BPF\_CORE\_READ ou une stratégie équivalente.
- Utiliser BTF/CO-RE lorsque disponible. Documenter la version kernel minimale effectivement testée.
- Conserver le programme verifier-friendly : bornes statiques, pas de boucle non bornée, taille d'événement raisonnable.
- Prévoir un event schema version pour permettre des évolutions sans casser le consumer.
- Ajouter une map de stats par CPU ou globale pour produced\_total, reserve\_failures, parse\_failures si pertinent.

## 7. Security engine - cible

Les règles simples peuvent être conservées comme signaux atomiques, mais les alertes importantes doivent devenir contextuelles. Exemple de corrélation attendue :

```
Rule: SECRET_READ_THEN_EXTERNAL_EGRESS
Window: 10 seconds
IF file.read matches sensitive_path_policy
AND network.connect destination NOT IN approved_destinations
AND both events belong to same session/process lineage
THEN severity = CRITICAL
Evidence = [file_event_id, network_event_id]
Reason = "Sensitive file read followed by unapproved external connection"
```

| Règle                      | Signal(s)                        | Sévérité cible | Test obligatoire                      |
|----------------------------|----------------------------------|----------------|---------------------------------------|
| SENSITIVE_FILE_READ        | lecture chemin sensible          | MEDIUM/HIGH    | positive + allowlisted false positive |
| SECRET_READ_THEN_EGRESS    | file read + external connect     | CRITICAL       | correlation window, lineage, timeout  |
| UNEXPECTED_PRIVILEGED_EXEC | exec + uid/capability/profile    | HIGH           | sudo-like + approved/admin profile    |
| DESTRUCTIVE_FILE_ACTION    | unlink/rename sur zone protégée  | HIGH/CRITICAL  | allowed tmp vs protected path         |
| BEHAVIORAL_BURST           | N exec/connect en courte fenêtre | MEDIUM/HIGH    | threshold boundary + reset window     |

## 8. Stratégie de tests - niveau requis

### PRINCIPE

Les tests doivent être capables de détecter une implémentation factice. Un test "live eBPF" n'est valide que si l'action déclenchante est un comportement réel du système et que l'événement attendu est observé via le consumer, sans injection directe dans le collector.

| Niveau             | But                                       | Privs        | Bloquant PR ?              |
|--------------------|-------------------------------------------|--------------|----------------------------|
| Unit               | modèles, décoder, règles, état            | non          | oui                        |
| Component          | collector sans kernel, repository, API    | non          | oui                        |
| Kernel integration | loader, attach, ringbuf, decode           | root/CAP_BPF | oui sur runner Linux dédié |
| End-to-end         | action système -> API                     | root/CAP_BPF | oui release                |
| Stress             | burst, drops, ressources                  | root/CAP_BPF | nightly/release            |
| Security scenarios | corrélations vraies/synthétiques séparées | mixte        | oui pour règles critiques  |
| Compatibility      | plusieurs kernels/distros                 | VM           | release/nightly            |

## 9. Batterie de tests obligatoire

### UT-01 - Decoder ABI valide

| Champ                               | Spécification                                                                |
|-------------------------------------|------------------------------------------------------------------------------|
| Préconditions                       | Fixture binaire produite avec le même layout que struct event.               |
| Action                              | Décoder un événement exec.                                                   |
| Assertions                          | Tous les champs identiques; aucune troncature; version reconnue.             |
| Anti-faux positif / anti-simulation | Le test compare offsets/tailles attendus, pas seulement les valeurs finales. |

### UT-02 - Decoder rejette payload tronqué

| Champ                               | Spécification                                                      |
|-------------------------------------|--------------------------------------------------------------------|
| Préconditions                       | Payload inférieur à sizeof(event).                                 |
| Action                              | Appeler decoder.                                                   |
| Assertions                          | Erreur structurée; decode_errors_total +1; aucun événement publié. |
| Anti-faux positif / anti-simulation | N/A                                                                |

### UT-03 - Decoder rejette version inconnue

| Champ         | Spécification       |
|---------------|---------------------|
| Préconditions | Header version=255. |
| Action        | Décoder.            |

| Champ                               | Spécification                   |
|-------------------------------------|---------------------------------|
| Assertions                          | Erreur contrôlée, pas de crash. |
| Anti-faux positif / anti-simulation | N/A                             |

## UT-04 - Machine d'état

| Champ                               | Spécification                                                    |
|-------------------------------------|------------------------------------------------------------------|
| Préconditions                       | Runtime mockable sans kernel.                                    |
| Action                              | Simuler succès/échec à chaque transition.                        |
| Assertions                          | Aucune transition illégale; STREAMING impossible avant ATTACHED. |
| Anti-faux positif / anti-simulation | N/A                                                              |

## UT-05 - Sequence gap

| Champ                               | Spécification                                                  |
|-------------------------------------|----------------------------------------------------------------|
| Préconditions                       | Séquences 10,11,14.                                            |
| Action                              | Ingestion.                                                     |
| Assertions                          | sequence_gaps_total augmente de 2 selon convention documentée. |
| Anti-faux positif / anti-simulation | N/A                                                            |

## UT-06 - Kernel drop counter parsing

| Champ                               | Spécification                              |
|-------------------------------------|--------------------------------------------|
| Préconditions                       | Stat map simulée.                          |
| Action                              | Lire compteurs.                            |
| Assertions                          | Valeurs monotones; reset/reload documenté. |
| Anti-faux positif / anti-simulation | N/A                                        |

## UT-07 - PID reuse

| Champ         | Spécification                                                 |
|---------------|---------------------------------------------------------------|
| Préconditions | Deux process identities même PID avec start times différents. |
| Action        | Corréler événements.                                          |

| Champ                               | Spécification                                   |
|-------------------------------------|-------------------------------------------------|
| Assertions                          | Aucun rattachement au processus mort précédent. |
| Anti-faux positif / anti-simulation | N/A                                             |

## UT-08 - Security correlation window

| Champ                               | Spécification                                        |
|-------------------------------------|------------------------------------------------------|
| Préconditions                       | File read + egress à t0/t0+9s, puis variante t0+11s. |
| Action                              | Évaluer règle.                                       |
| Assertions                          | Alerte dans fenêtre; aucune hors fenêtre.            |
| Anti-faux positif / anti-simulation | N/A                                                  |

## UT-09 - Security lineage

| Champ                               | Spécification                                             |
|-------------------------------------|-----------------------------------------------------------|
| Préconditions                       | Événements sur enfant du même agent puis process externe. |
| Action                              | Évaluer.                                                  |
| Assertions                          | Corrélation seulement dans la lignée/session correcte.    |
| Anti-faux positif / anti-simulation | N/A                                                       |

## UT-10 - Pagination bornée

| Champ                               | Spécification                                              |
|-------------------------------------|------------------------------------------------------------|
| Préconditions                       | API avec dataset synthétique.                              |
| Action                              | limit très grand, négatif, offset extrême.                 |
| Assertions                          | 422/normalisation selon spec; jamais de réponse illimitée. |
| Anti-faux positif / anti-simulation | N/A                                                        |

## KI-01 - Load et attach réels

| Champ         | Spécification                                                                              |
|---------------|--------------------------------------------------------------------------------------------|
| Préconditions | Linux compatible, root/CAP_BPF, BTF selon cible.                                           |
| Action        | Démarrer collector.                                                                        |
| Assertions    | État atteint ATTACHED puis STREAMING; pin/link/map réellement présents ou introspectables. |



| Champ                               | Spécification                                                                    |
|-------------------------------------|----------------------------------------------------------------------------------|
| Anti-faux positif / anti-simulation | Interdire monkeypatch de load_and_attach; inspecter kernel/bpftool/libbpf state. |

## KI-02 - Exec /bin/echo capturé

| Champ                               | Spécification                                                                                              |
|-------------------------------------|------------------------------------------------------------------------------------------------------------|
| Préconditions                       | Collector live démarré.                                                                                    |
| Action                              | subprocess.run(["/bin/echo","agentsight-e2e-marker"]).                                                     |
| Assertions                          | Événement reçu; filename correspond; PID correspond au child réel; timestamp plausible; received_total +1. |
| Anti-faux positif / anti-simulation | Le test ne crée jamais ProcessExecutionEvent attendu.                                                      |

## KI-03 - Exec inexistant non capturé comme succès

| Champ                               | Spécification                                                                                                  |
|-------------------------------------|----------------------------------------------------------------------------------------------------------------|
| Préconditions                       | Collector live.                                                                                                |
| Action                              | Tenter exec d'un chemin inexistant.                                                                            |
| Assertions                          | Aucun sched_process_exec succès pour ce chemin, selon sémantique hook; erreur utilisateur observée séparément. |
| Anti-faux positif / anti-simulation | N/A                                                                                                            |

## KI-04 - Process tree réel

| Champ                               | Spécification                                                      |
|-------------------------------------|--------------------------------------------------------------------|
| Préconditions                       | Collector live.                                                    |
| Action                              | Parent Python fork/spawn -> child /bin/sh -> grandchild /bin/echo. |
| Assertions                          | Tous exec observés; parentage/session lineage cohérents.           |
| Anti-faux positif / anti-simulation | N/A                                                                |

## KI-05 - Process exit

| Champ         | Spécification                                              |
|---------------|------------------------------------------------------------|
| Préconditions | Probe exit actif.                                          |
| Action        | Lancer un process court.                                   |
| Assertions    | Exec puis exit; état processus fermé; pas de process actif |

| Champ                               | Spécification |
|-------------------------------------|---------------|
|                                     | fantôme.      |
| Anti-faux positif / anti-simulation | N/A           |

## KI-06 - UID/GID et comm

| Champ                               | Spécification                                  |
|-------------------------------------|------------------------------------------------|
| Préconditions                       | Runner avec utilisateur test lorsque possible. |
| Action                              | Exécuter commande sous identité contrôlée.     |
| Assertions                          | uid/gid/comm correspondent au système.         |
| Anti-faux positif / anti-simulation | N/A                                            |

## KI-07 - Unicode/long filename

| Champ                               | Spécification                                                           |
|-------------------------------------|-------------------------------------------------------------------------|
| Préconditions                       | Créer/exécuter cible avec chemin long supporté et/ou caractères permis. |
| Action                              | Exec.                                                                   |
| Assertions                          | Troncature documentée, NUL termination correcte, aucun overread.        |
| Anti-faux positif / anti-simulation | N/A                                                                     |

## KI-08 - Restart propre

| Champ                               | Spécification                                                                  |
|-------------------------------------|--------------------------------------------------------------------------------|
| Préconditions                       | Collector live.                                                                |
| Action                              | start -> event -> stop -> start -> event.                                      |
| Assertions                          | Pas de FD/link/map leak; second run reçoit exactement les nouveaux événements. |
| Anti-faux positif / anti-simulation | N/A                                                                            |

## E2E-01 - Kernel -> API timeline

| Champ         | Spécification                                  |
|---------------|------------------------------------------------|
| Préconditions | Serveur API + collector live.                  |
| Action        | Exec réel /bin/echo puis GET timeline/session. |

| Champ                               | Spécification                                                                       |
|-------------------------------------|-------------------------------------------------------------------------------------|
| Assertions                          | L'événement du PID réel apparaît via API, contenu cohérent, latence < seuil défini. |
| Anti-faux positif / anti-simulation | N/A                                                                                 |

## E2E-02 - Kernel -> security alert -> API

| Champ                               | Spécification                                                                                              |
|-------------------------------------|------------------------------------------------------------------------------------------------------------|
| Préconditions                       | Probes requis actifs, politique test.                                                                      |
| Action                              | Lire fichier sensible fixture puis connexion locale classée externe par policy test ou scénario sandbox.   |
| Assertions                          | Alerte corrélée visible via API avec evidence IDs; aucune alerte si destination allowlistée.               |
| Anti-faux positif / anti-simulation | Ne jamais utiliser de secret réel ni Internet public; utiliser namespace/container/service local contrôlé. |

## E2E-03 - Readiness

| Champ                               | Spécification                                                                      |
|-------------------------------------|------------------------------------------------------------------------------------|
| Préconditions                       | API démarrée avant collector puis après streaming.                                 |
| Action                              | GET /ready.                                                                        |
| Assertions                          | 503/non-ready avant streaming; 200 seulement lorsque composants requis sont prêts. |
| Anti-faux positif / anti-simulation | N/A                                                                                |

## E2E-04 - Auth mode

| Champ                               | Spécification                                                       |
|-------------------------------------|---------------------------------------------------------------------|
| Préconditions                       | Auth activée.                                                       |
| Action                              | Appels sans/avec jeton.                                             |
| Assertions                          | 401/403 sans droit; 200 avec droit; aucun endpoint sensible oublié. |
| Anti-faux positif / anti-simulation | N/A                                                                 |

## ST-01 - Burst exec

| Champ         | Spécification   |
|---------------|-----------------|
| Préconditions | Collector live. |

| Champ                               | Spécification                                                                       |
|-------------------------------------|-------------------------------------------------------------------------------------|
| Action                              | Lancer 1k-10k process courts selon capacité runner, avec limite de temps.           |
| Assertions                          | Pas de deadlock/crash; counts cohérents; pertes explicitement mesurées; RSS bornée. |
| Anti-faux positif / anti-simulation | N/A                                                                                 |

## ST-02 - Ring buffer saturation contrôlée

| Champ                               | Spécification                                                                        |
|-------------------------------------|--------------------------------------------------------------------------------------|
| Préconditions                       | Ringbuf de test réduit ou consumer volontairement ralenti.                           |
| Action                              | Produire burst.                                                                      |
| Assertions                          | reserve_failures/kernel_drops >0; métriques exactes/monotones; service reste vivant. |
| Anti-faux positif / anti-simulation | N/A                                                                                  |

## ST-03 - Userspace queue saturation

| Champ                               | Spécification                                                                 |
|-------------------------------------|-------------------------------------------------------------------------------|
| Préconditions                       | Queue bornée petite.                                                          |
| Action                              | Ralentir pipeline aval + burst.                                               |
| Assertions                          | userspace_queue_drops >0 distinct de kernel_drops; pas de mémoire non bornée. |
| Anti-faux positif / anti-simulation | N/A                                                                           |

## ST-04 - Soak test

| Champ                               | Spécification                                                                |
|-------------------------------------|------------------------------------------------------------------------------|
| Préconditions                       | Runner dédié.                                                                |
| Action                              | Charge modérée 30-60 min nightly.                                            |
| Assertions                          | RSS/FD stabilisés; pas de fuite continue; taux decode error nul ou expliqué. |
| Anti-faux positif / anti-simulation | N/A                                                                          |

## ST-05 - Concurrent API reads

| Champ                               | Spécification                                                       |
|-------------------------------------|---------------------------------------------------------------------|
| Préconditions                       | Dataset live + charge events.                                       |
| Action                              | 20-100 clients GET timeline/stats selon runner.                     |
| Assertions                          | Pas de race/500; p95 sous seuil; consistency acceptable documentée. |
| Anti-faux positif / anti-simulation | N/A                                                                 |

## FT-01 - Missing privileges

| Champ                               | Spécification                                                                  |
|-------------------------------------|--------------------------------------------------------------------------------|
| Préconditions                       | Linux sans CAP_BPF/root.                                                       |
| Action                              | Start.                                                                         |
| Assertions                          | Échec explicite UNSUPPORTED/PREFLIGHT error; aucune assertion "injected=true". |
| Anti-faux positif / anti-simulation | N/A                                                                            |

## FT-02 - Missing clang/bpftool/libbpf

| Champ                               | Spécification                                                       |
|-------------------------------------|---------------------------------------------------------------------|
| Préconditions                       | Masquer outil requis selon backend.                                 |
| Action                              | Start.                                                              |
| Assertions                          | Message actionnable; exit/status propre; API health reflète erreur. |
| Anti-faux positif / anti-simulation | N/A                                                                 |

## FT-03 - Invalid BPF object

| Champ                               | Spécification                                   |
|-------------------------------------|-------------------------------------------------|
| Préconditions                       | Injecter objet invalide dans test du loader.    |
| Action                              | Load.                                           |
| Assertions                          | ERROR; stderr capturé; nettoyage des artefacts. |
| Anti-faux positif / anti-simulation | N/A                                             |

## FT-04 - Consumer callback exception

| Champ                               | Spécification                                                                            |
|-------------------------------------|------------------------------------------------------------------------------------------|
| Préconditions                       | Forcer erreur decoder sur un record.                                                     |
| Action                              | Poll.                                                                                    |
| Assertions                          | Compteur erreur; policy continue ou fail-fast documentée; pas de thread mort silencieux. |
| Anti-faux positif / anti-simulation | N/A                                                                                      |

## FT-05 - API during collector failure

| Champ                               | Spécification                                                                       |
|-------------------------------------|-------------------------------------------------------------------------------------|
| Préconditions                       | Collector en ERROR.                                                                 |
| Action                              | GET health/timeline.                                                                |
| Assertions                          | Health non-ready; données historiques éventuellement lisibles; aucune fausse santé. |
| Anti-faux positif / anti-simulation | N/A                                                                                 |

## 10. Scénarios sécurité puissants

| ID     | Scénario                                                      | Attendu                                             |
|--------|---------------------------------------------------------------|-----------------------------------------------------|
| SEC-01 | lecture fixture .env puis connexion destination non approuvée | CRITICAL corrélé                                    |
| SEC-02 | lecture même fixture puis connexion allowlist                 | pas CRITICAL; INFO/none selon policy                |
| SEC-03 | curl vers domaine approuvé sans lecture sensible              | pas HIGH automatique                                |
| SEC-04 | python ouvre socket sans binaire curl/wget                    | activité réseau détectée malgré commande non listée |
| SEC-05 | rm dans /tmp sandbox                                          | pas destructive critical                            |
| SEC-06 | unlink dans répertoire protégé sandbox                        | HIGH/CRITICAL                                       |
| SEC-07 | process externe lit secret pendant session agent              | ne pas attribuer à l'agent si hors lineage          |
| SEC-08 | child/grandchild agent lit secret                             | doit être attribué à la session via lineage         |
| SEC-09 | même événements séparés au-delà de fenêtre                    | pas de corrélation                                  |
| SEC-10 | burst de 100 connexions/exec dans fenêtre                     | behavioral alert selon seuil                        |

## 11. Fuzzing, property tests et robustesse

- Fuzzer decoder binaire : tailles 0..2x sizeof(event), bytes aléatoires, chaînes sans NUL, version inconnue; objectif zéro crash/overread.
- Property test SessionManager : un événement ne peut appartenir qu'à une seule session active selon l'identité process définie; PID reuse ne doit pas violer l'invariant.
- Property test pagination : concaténer toutes les pages sans mutation doit reconstruire le même ensemble trié sans doublon/omission.
- Fuzz des filtres API : chaînes longues, regex-like text si applicable, encodages, timestamps extrêmes; pas de 500.
- Fuzz policy/security : chemins extrêmement longs, IPv4/IPv6, hostnames invalides, UID extrêmes; comportement déterministe.

## 12. Gates de performance et qualité

| Gate                     | Valeur de départ recommandée            | Remarque                                                          |
|--------------------------|-----------------------------------------|-------------------------------------------------------------------|
| Unit/component tests     | 100% pass                               | zéro flaky accepté                                                |
| Kernel e2e               | 100% pass sur runner dédié              | retry global interdit pour masquer flaky; debug artifact autorisé |
| Decoder crash            | 0                                       | sur corpus + fuzz court PR                                        |
| Memory growth soak       | pas de croissance linéaire              | seuil chiffré à calibrer après baseline                           |
| FD/link leak restart     | 0 leak net après cycles                 | vérifier /proc/<pid>/fd + BPF links                               |
| API 5xx sous charge test | 0                                       | hors injection volontaire de panne                                |
| Coverage Python          | >= 85% global; >= 95% modules critiques | ne pas poursuivre la couverture au détriment des tests live       |
| Static quality           | ruff/format + mypy/pyright cible        | zéro erreur bloquante                                             |
| Security critical rules  | 100% positive + negative cases          | preuves et anti-faux positifs                                     |

Les seuils de latence/overhead doivent être baselinés sur une machine de référence avant d'être figés. Ne pas inventer un "<3% overhead" sans benchmark reproductible. Ajouter un script benchmark qui compare workload avec et sans collector sur plusieurs répétitions et publie médiane/p95.

## 13. Organisation CI/CD recommandée

```
jobs:
  lint-type-unit:
    no privileges
    every PR

  component-api:
    no privileges
    every PR

  ebpf-build-verifier:
    Linux + clang/llvm + BTF
    compile and verify object
    every PR

  kernel-integration:
    privileged dedicated runner / VM
    KI-* and E2E-*
    every protected-branch PR or merge queue

  stress-soak:
    dedicated runner
    ST-* + fuzz extended
    nightly + release

  compatibility-matrix:
    VM matrix across supported kernels/distros
    nightly + release
```

Important : les runners GitHub-hosted standards ne sont pas toujours adaptés aux tests eBPF privilégiés. Prévoir un runner Linux dédié, une VM CI contrôlée ou une infrastructure compatible. Les tests kernel doivent être automatiquement sautés avec une raison explicite uniquement hors environnement privilégié; ils doivent être obligatoires dans la pipeline dédiée.

## 14. Plan de modifications par fichiers

| Zone                       | Actions attendues                                                                      |
|----------------------------|----------------------------------------------------------------------------------------|
| src/ebpf/probe.c           | corriger ringbuf semantics; stats/drop map; schema version; exec/exit; CO-RE si adopté |
| src/collector/collector.py | séparer preflight/loader/consumer; state machine; queue bornée; metrics; cleanup       |
| src/collector/*runtime*    | idéalement extraire BPFProbeRuntime + RingBufferConsumer dans modules dédiés           |
| src/models/*               | event header/version, process identity/start time, validation                          |
| src/collector/security.py  | rule ids stables, policy config, correlation windows/evidence                          |
| src/api/server.py          | health/ready, auth configurable, bounds pagination, repository abstraction             |
| tests/unit/                | decoder, state, models, session, rules, API validation                                 |
| tests/integration/         | component pipeline sans kernel + persistence                                           |
| tests/kernel/              | vrais tests privilégiés KI-*                                                           |
| tests/e2e/                 | kernel -> security -> API                                                              |



| Zone               | Actions attendues                                                          |
|--------------------|----------------------------------------------------------------------------|
| tests/stress/      | burst, saturation, soak, concurrency                                       |
| scripts/bench/     | benchmark reproducible overhead/latency                                    |
| .github/workflows/ | split CI jobs et runner labels                                             |
| README.md          | matrice "réel vs simulé", prereqs, commandes tests, limitations factuelles |

## 15. Definition of Done

- Une commande réelle `/bin/echo` génère un événement eBPF observé par le consumer Python et visible via API.
- Aucun test nommé "real", "kernel" ou "e2e" ne construit l'événement qu'il prétend observer depuis le kernel.
- Les pertes kernel et userspace sont distinguées, exposées et testées.
- Le collector redémarre proprement sans fuite de BPF links, FDs ou threads/tâches.
- PID reuse et process exit sont couverts.
- Les règles critiques ont tests positifs, négatifs, limites temporelles et lineage.
- Le README distingue précisément les features kernel-live des fallbacks/simulations.
- La CI contient un job privilégié qui exécute réellement les tests kernel.
- Tous les tests unit/component passent sans privilèges; les tests kernel passent sur l'environnement dédié.
- Le code lint/type-check est propre et les erreurs runtime sont structurées/actionnables.

## 16. Prompt maître à donner à GitHub Copilot

Le bloc suivant peut être donné tel quel à Copilot dans le repository. Le PDF entier reste la spécification de référence.

You are working on the AgentSight repository. Treat this PDF as the implementation specification and acceptance contract.

Goal: turn the current prototype into a genuinely end-to-end eBPF prototype on Linux. Do not merely improve simulations.

Non-negotiable requirements:

1. Implement a real userspace consumer for the BPF ring buffer.
2. Make runtime states truthful: preflight != loaded != attached != streaming.
3. Fix ring-buffer loss semantics and expose separate kernel-drop, sequence-gap, decode-error and userspace-queue-drop metrics.
4. Add process-exit tracking and robust PID reuse/session correlation.
5. Prefer CO-RE/BTF/libbpf where practical and make attach semantics correct for the program type.
6. Keep file/network features explicitly labeled as simulated/fallback unless they have real kernel probes.
7. Strengthen the security engine with contextual multi-event correlations and stable rule IDs/evidence.
8. Add health/readiness and secure API behavior as specified.
9. Reorganize tests into unit/component/kernel/e2e/stress/security suites.
10. Implement all mandatory KI/E2E/ST/FT/SEC tests from the specification.

Critical test rule:

A test called real/kernel/e2e MUST NOT construct the expected ProcessExecutionEvent/FileAccessEvent/NetworkConnectionEvent directly. It must trigger a real OS action and verify that the event arrives through the live collector path.

Workflow:

- First inspect the current repository; do not assume this PDF's file line numbers or old implementation details are unchanged.
- Make small coherent commits/patches by layer.
- Run the fastest relevant tests after each layer.
- Do not delete useful existing tests; rename simulated tests if their names overclaim reality.
- Add observability to make failures diagnosable.
- If an environment cannot execute privileged eBPF tests, keep them implemented and clearly skipped there, but provide exact commands for the privileged runner.
- Never mark the task complete while KI-02 (real /bin/echo capture) or E2E-01 (kernel -> API timeline) is unimplemented.

Completion report must include:

- files changed,
- architecture decisions,
- exact commands run,
- test results by suite,
- which tests require privileges,
- any remaining limitations,
- evidence that /bin/echo was captured from the kernel and surfaced through the API.

## 17. Commandes de validation attendues

Adapter les commandes au packaging final, mais conserver une séparation claire entre suites :

```
# Fast PR suite
pytest -q tests/unit tests/component

# Kernel live suite (privileged Linux runner)
sudo -E pytest -q -m kernel tests/kernel

# End-to-end
sudo -E pytest -q -m e2e tests/e2e

# Stress (dedicated runner)
sudo -E pytest -q -m stress tests/stress

# Security rules/scenarios
pytest -q -m security tests/security

# Static quality
ruff check .
ruff format --check .
# mypy src OR pyright src

# Optional sanitizer/native bridge tests
# build native consumer with ASan/UBSan when applicable
```

## 18. Checklist finale pour revue humaine

- ☐ Le probe compile sur l'environnement documenté.
- ☐ Le programme est réellement attaché.
- ☐ Le consumer lit réellement la map ring buffer.
- ☐ Le marker /bin/echo est capturé avec le PID réel.
- ☐ Le même événement traverse SessionManager.
- ☐ Le même événement est visible via API.
- ☐ Le processus exit est observé et ferme l'état.
- ☐ Un test de saturation fait monter un compteur de pertes sans crash.
- ☐ Un restart ne laisse pas de links/FDs.
- ☐ Une règle corrélée secret-read -> egress produit une alerte avec preuves.
- ☐ Le cas allowlist équivalent ne produit pas le faux positif critique.
- ☐ README et noms de tests ne sur-vendent pas les fonctionnalités.
- ☐ CI privileged kernel suite existe et est bloquante pour release.
- ☐ Le rapport Copilot indique clairement les limites restantes.

## 19. Références techniques et périmètre analysé

Périmètre de code analysé lors de la relecture : README.md, src/collector/collector.py, src/collector/security.py, src/api/server.py, src/ebpf/probe.c, tests/test\_agentsight.py, test\_real\_system.py, test\_real\_comprehensive.py et requirements.txt. Copilot doit relire la branche courante avant chaque modification car le dépôt peut évoluer après la génération de ce document.

- Linux kernel tracepoint definition: include/trace/events/sched.h (sched\_process\_exec / sched\_process\_exit).
- Linux BPF ring buffer documentation: BPF\_MAP\_TYPE\_RINGBUF; reserve failure means the new record is not produced.
- libbpf / CO-RE documentation for portable BPF program loading, maps and links.
- Repository: <https://github.com/xsai1992/preemptics-test>